



Facultad de Estadística e Informática

Universidad Veracruzana

Licenciatura en Ingeniería de Ciberseguridad e Infraestructura de Cómputo

Anteproyecto

Estado del arte de las medidas de seguridad a nivel de aplicación en el contexto de ataques de inyección de prompt dirigidos a sistemas basados en LLM

Abraham Núñez Sánchez

19 de Julio del 2026

“Lis de Veracruz: Arte, Ciencia, Luz”



Datos para Registro de Trabajo Recepcional

Datos del Trabajo Recepcional (TR)

Título:	Análisis de la seguridad a nivel de aplicación en el contexto de ataques de inyección de prompt dirigidos a sistemas basados en LLM
Director:	Héctor Xavier Limón Riaño
Codirector:	
Modalidad:	Monografía
Duración estimada en meses:	18 meses
Requisitos	

Datos del Estudiante

Nombre del (los) Alumno(s):	Abraham Núñez Sánchez
Matrícula (s):	zS23013842
Correo(s) electrónico(s)	zS23013842@estudiantes.uv.mx

Datos del Proyecto de Investigación

Nombre del proyecto de Investigación:	Fortalecimiento de la ciberseguridad y tecnologías de la información para la academia, las organizaciones y la sociedad
Cuerpo Académico:	Grupo de investigación: Ciberseguridad y Tecnologías de la Información
LGAC que alimenta:	Tecnologías de la información y ciberseguridad en las organizaciones y la sociedad.
Descripción del proyecto:	
En nuestro contexto actual, el aumento de la digitalización y la transformación digital en todos los sectores está generando nuevos desafíos en materia de ciberseguridad y en todo	

lo referente a las tecnologías de la información. La protección de información, la prevención y la privacidad digital se han convertido en los últimos años en una alta prioridad tanto para las organizaciones del sector público y privado, como para las organizaciones académicas. En este sentido se plantea el proyecto Fortalecimiento de la Ciberseguridad y Tecnologías de la Información para la Academia, las Organizaciones y la sociedad, que busca fortalecer el conocimiento para la aplicación de la ciberseguridad y las tecnologías de la información en ámbitos académicos, organizacionales y sociales, mediante acciones que contribuyan al desarrollo digital

Descripción del Trabajo Recepcional

Antecedentes

En los últimos años, la inteligencia artificial generativa y los modelos grandes de lenguaje (LLM) han pasado a integrarse en aplicaciones de uso práctico en diferentes ámbitos, incluyendo la ciberseguridad, dando apoyo para tareas como el análisis de vulnerabilidades, la automatización de tareas y la gestión de riesgos. Mirtaheri et al. (2026) analizaron más de 100 publicaciones entre 2021 y 2025 sobre IA generativa aplicada a la evaluación de vulnerabilidades y gestión de riesgos, identificando aplicaciones ofensivas y defensivas, así como retos asociados con la seguridad, la explicabilidad y la confiabilidad. Esta revisión permite contextualizar que la IA generativa ya forma parte de procesos técnicos y que su uso requiere mecanismos de control y evaluación durante su operación.

De forma más específica, en el campo de la seguridad de los LLM se ha identificado la inyección de prompt, o prompt injection en inglés, como una amenaza relevante para aplicaciones basadas en estos modelos. En este contexto, un ataque de prompt injection puede entenderse como un ataque en el que un atacante da instrucciones maliciosas dentro de una entrada, consulta, documento, página web, salida de herramienta u otra fuente de datos procesada por un sistema basado en LLM, con el propósito de alterar el comportamiento esperado del modelo o del sistema que lo integra. Estas instrucciones pueden buscar que el LLM ignore reglas previas, modifique su respuesta, revele información sensible, ejecute acciones no previstas o favorezca los objetivos del atacante. La inyección puede ser directa, cuando el atacante introduce la instrucción maliciosa en el prompt que envía al sistema, o indirecta, cuando dicha instrucción se encuentra oculta en datos externos que el sistema recupera y procesa durante su operación. Vassilev et al.

(2025) clasifican los ataques contra IA generativa e incluyen secciones específicas sobre inyección de prompt directa e indirecta, además de describir mitigaciones y su relación con la seguridad de agentes basados en modelos de IA generativa.

Para este trabajo, se entenderá por sistema basado en LLM a una aplicación o entorno de software que utiliza un modelo grande de lenguaje como componente principal para procesar instrucciones en lenguaje natural y generar respuestas, pero que además puede integrar otros elementos operativos, como prompts del sistema, entradas del usuario, documentos externos, bases de datos, APIs, herramientas, validadores, filtros, registros de actividad o mecanismos de control.

También para este trabajo, el nivel de aplicación se refiere al conjunto de técnicas, controles y procesos aplicados por quienes utilizan, integran, despliegan o evalúan modelos LLM dentro de aplicaciones y plataformas. Por lo tanto, no se refiere al entrenamiento o modificación interna del modelo, sino a las medidas implementadas alrededor del LLM durante su uso: procesamiento de entradas, construcción del prompt, manejo del contexto, detección de contenido malicioso, validación de salidas, control de herramientas, monitoreo, registro de actividad y evaluación de mitigaciones.

Una segunda revisión reciente, elaborada por Wang et al. (2026), presenta una sistematización del campo de prompt injection. Este trabajo revisa 78 artículos y organiza los ataques de acuerdo con sus estrategias de generación de payloads, así como las defensas según su etapa de intervención: nivel de texto, nivel de modelo y nivel de ejecución. Esto resulta útil para el trabajo, ya que permite delimitar el análisis hacia mitigaciones aplicadas durante el procesamiento u operación del sistema, sin entrar en técnicas de entrenamiento o modificación interna del modelo. Por lo tanto, el análisis no se centrará en modificar el modelo LLM en sí mismo, sino en las técnicas aplicadas alrededor de este durante su operación.

Problemática

El problema técnico surge porque los LLM procesan instrucciones y datos en lenguaje natural dentro de un mismo flujo de entrada. En aplicaciones integradas con LLM, esta característica puede provocar que el modelo no distinga adecuadamente entre una instrucción legítima del sistema o del usuario y una instrucción maliciosa contenida en datos externos. Greshake et al. (2023) muestran que las aplicaciones integradas con LLM

difuminan la línea entre datos e instrucciones, lo que permite que instrucciones maliciosas colocadas en fuentes externas sean recuperadas y procesadas durante la inferencia.

Esta vulnerabilidad no se limita a ataques manuales o evidentes. Liu et al. (2024) proponen ataques automáticos y universales de prompt injection contra LLM, es decir, ataques diseñados para ser aplicables a múltiples modelos. Los autores señalan que muchas evaluaciones dependen de prompts escritos manualmente, lo cual dificulta medir de forma robusta la seguridad frente a ataques más adaptativos.

Asimismo, Liu et al. (2024) formalizan y evalúan ataques y defensas de inyección de prompt, lo que permite considerar criterios comparativos para analizar mitigaciones operativas. Por su parte, Chen et al. (2025) proponen una defensa que aprovecha técnicas de ataque con fines defensivos, lo cual resulta relevante para discutir propuestas recientes de mitigación frente a este tipo de amenazas.

Frente a esta problemática, existen diferentes propuestas para mitigar este tipo de ataques para distintos contextos. Una propuesta de mitigación a nivel operativo consiste en detectar entradas contaminadas antes de que afecten al sistema LLM. Liu et al. (2025) proponen DataSentinel, un método de detección en el que un LLM detector identifica datos contaminados con prompts inyectados. El estudio evalúa el método en distintas tareas objetivo, tareas inyectadas, modelos y ataques existentes, además de ataques adaptativos. Otra propuesta se observa en el contexto de aplicaciones Text-to-SQL. En este tipo de sistemas, los LLM pueden ser utilizados como interfaces para bases de datos, lo que introduce riesgos si un atacante logra manipular el prompt para generar consultas no autorizadas. Ding y Labrinidis (2025) proponen comparar la similitud semántica entre prompts entrantes y un conjunto de patrones maliciosos conocidos como mecanismo de mitigación operativa.

Además de detectar ataques concretos, también se requiere evaluar la postura de seguridad de las aplicaciones basadas en LLM. Karlsen et al. (2026) proponen un marco de seguridad para aplicaciones LLM, señalando que los métodos tradicionales de aseguramiento no capturan adecuadamente vulnerabilidades específicas como prompt injection, manejo inseguro de salidas o envenenamiento de datos. Su propuesta traduce requisitos y vulnerabilidades en métricas medibles, usando CVSS v4.0 y alineación con OWASP Top 10 for LLMs.

Objetivo

El objetivo general de este trabajo es analizar los vectores de ataques y, por tanto, las técnicas de mitigación a nivel de aplicación contra ataques de inyección de prompt dirigidos a sistemas basados en LLM, mediante una revisión documental de literatura técnica y científica reciente, con el fin de clasificar las mitigaciones evaluadas, describir sus alcances y limitaciones, y discutir sus criterios de aplicación en escenarios donde los LLM son utilizados o integrados en aplicaciones y plataformas, sin intervenir en el entrenamiento o modificación interna del modelo.

Preguntas de Investigación

Pregunta principal:

¿Qué técnicas de mitigación a nivel de aplicación, como controles durante la integración y el uso del LLM en aplicaciones, contra ataques de inyección de prompt dirigidos a sistemas basados en LLM han sido evaluadas en la literatura reciente, y qué alcances, limitaciones y criterios de aplicación presentan?

1. ¿Qué son los ataques de inyección de prompt?
 - 1.1. ¿Cuáles son los principales objetivos de los ataques de inyección de prompt?
 - 1.2. ¿Qué tipos o categorías de ataques de inyección de prompt se han identificado en la literatura reciente?
 - 1.3. ¿Los objetivos del ataque cambian dependiendo del tipo de inyección de prompt, por ejemplo, directa o indirecta?
2. ¿Qué técnicas de mitigación se han propuesto para reducir ataques de inyección de prompt en sistemas basados en LLM?
 - 2.1. ¿Qué mitigaciones existen específicamente a nivel de aplicación, es decir, aplicadas durante la integración, despliegue o uso del sistema basado en LLM, sin modificar el entrenamiento o la arquitectura interna del modelo?
 - 2.2. ¿Cómo pueden clasificarse las mitigaciones operativas según el momento en que intervienen?
3. ¿Las mitigaciones operativas identificadas cubren todas las categorías de ataques de inyección de prompt?
 - 3.1. ¿Qué limitaciones presentan las mitigaciones actuales frente a ataques de inyección de prompt?

3.2. ¿Cómo se evalúan las mitigaciones contra ataques de inyección de prompt en términos de efectividad, utilidad, costo, facilidad de implementación y riesgo residual?

Justificación

Esta investigación es conveniente porque los sistemas basados en LLM se están integrando en aplicaciones capaces de procesar documentos, consultar bases de datos, interactuar con navegadores, utilizar APIs, generar código, responder preguntas, analizar información y apoyar procesos de automatización. Esta evolución incrementa su superficie de ataque, especialmente cuando reciben instrucciones o datos provenientes de usuarios, documentos o fuentes externas.

La inyección de prompt es una amenaza relevante porque aprovecha la forma en que los LLM procesan instrucciones en lenguaje natural. Un atacante puede construir entradas diseñadas para alterar el comportamiento del modelo, evadir restricciones, modificar la respuesta esperada, inducir acciones no autorizadas o intentar obtener información sensible. En el caso de la inyección indirecta, el riesgo aumenta porque la instrucción maliciosa puede encontrarse en una fuente externa aparentemente legítima, como un documento, una página web, un correo, una salida de herramienta o un registro procesado por el sistema.

En un escenario práctico, un usuario podría pedir a un sistema LLM que resuma un documento, analice una página web o genere una consulta a partir de información externa sin saber que dicha fuente contiene instrucciones maliciosas ocultas. Si el sistema interpreta esas instrucciones como parte válida de la tarea, puede generar respuestas manipuladas, producir salidas inseguras o facilitar el uso indebido de recursos conectados.

Además, investigaciones recientes muestran que no basta con evaluar defensas frente a ataques manuales o evidentes, ya que existen ataques automáticos, universales o adaptativos que pueden superar mitigaciones simples. Por ello, resulta necesario analizar qué técnicas de mitigación pueden aplicarse durante la operación del sistema, sin modificar el modelo base ni intervenir en su entrenamiento.

El trabajo contribuirá a organizar y comparar mitigaciones evaluadas en la literatura reciente, identificando sus alcances, limitaciones y criterios de aplicación frente a ataques de inyección de prompt en sistemas basados en LLM.

No se pretende ofrecer una guía definitiva de implementación para quienes desarrollan, entrenan o modifican la arquitectura interna de los modelos LLM, sino aportar a la comunidad académica y a personal de ciberseguridad una revisión organizada que permita comprender el estado actual de los vectores de ataque y las mitigaciones contra ataques de inyección de prompt. La investigación busca aportar una revisión organizada de mitigaciones operativas que permita comprender qué controles se han evaluado, en qué etapa del sistema intervienen y qué limitaciones presentan frente a ataques de inyección de prompt.

Resultados esperados

Se espera obtener una revisión documental organizada sobre ataques de inyección de prompt dirigidos a sistemas basados en LLM, considerando sus objetivos, tipos principales y formas de manifestación. También se espera construir un catálogo de técnicas de mitigación a nivel de aplicación, enfocado en mecanismos aplicados durante el procesamiento de entradas, generación de respuestas, validación de salidas, control de herramientas y monitoreo del sistema, sin considerar técnicas que requieran modificar el modelo base.

Otro resultado esperado es elaborar una comparativa de mitigaciones evaluadas en la literatura, considerando criterios como etapa de intervención, tipo de ataque cubierto, efectividad reportada, impacto en la utilidad, costo, facilidad de implementación, limitaciones y riesgo residual. Además, se espera identificar brechas o áreas problemáticas en las mitigaciones actuales.

Bibliografía recomendada

- Chen, Y., Li, H., Zheng, Z., Wu, D., Song, Y., & Hooi, B. (2025). Defense against prompt injection attack by leveraging attack techniques. In W. Che, J. Nabende, E. Shutova, & M. T. Pilehvar (Eds.), Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers) (pp.

18331–18347). Association for Computational Linguistics.
<https://doi.org/10.18653/v1/2025.acl-long.897>

- Ding, Z. H., & Labrinidis, A. (2025). DaMIT-SQL: Detecting and mitigating Text-to-SQL prompt injection attacks. En 2025 IEEE International Conference on Collaborative Advances in Software and Computing (CASCON). IEEE.
<https://doi.org/10.1109/CASCON66301.2025.00116>
- Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. En Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (pp. 79–90). Association for Computing Machinery. <https://doi.org/10.1145/3605764.3623985>
- Karlsen, S. S., Yamin, M. M., Hashmi, E., Katt, B., & Ullah, M. (2026). Securing large language models: A quantitative assurance framework approach. Journal of Information Security and Applications, 97, 104351.
<https://doi.org/10.1016/j.jisa.2025.104351>
- Liu, X., Yu, Z., Zhang, Y., Zhang, N., & Xiao, C. (2024). Automatic and universal prompt injection attacks against large language models. arXiv.
<https://arxiv.org/abs/2403.04957>
- Liu, Y., Jia, Y., Jia, J., Song, D., & Gong, N. Z. (2025). DataSentinel: A game-theoretic detection of prompt injection attacks. En 2025 IEEE Symposium on Security and Privacy (SP). IEEE. <https://doi.org/10.1109/SP61157.2025.00250>
- Liu, Y., Jia, Y., Geng, R., Jia, J., & Gong, N. Z. (2024). Formalizing and benchmarking prompt injection attacks and defenses. In 33rd USENIX Security Symposium (USENIX Security 24) (pp. 1831–1847). USENIX Association.
<https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupei>
- Mirtaheri, S. L., Movahed, N., Shahbazian, R., Pascucci, V., & Pugliese, A. (2026). Cybersecurity in the age of generative AI: A systematic taxonomy of AI-powered vulnerability assessment and risk management. Future Generation Computer Systems, 175, 108107. <https://doi.org/10.1016/j.future.2025.108107>

- Vassilev, A., Oprea, A., Fordyce, A., Anderson, H., Davies, X., & Hamin, M. (2025). Adversarial machine learning: A taxonomy and terminology of attacks and mitigations (NIST AI 100-2e2025). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.AI.100-2e2025>
- Wang, P., Li, X., Xiang, C., Zhang, J., Li, Y., Zhang, L., Wang, X., & Tian, Y. (2026). The landscape of prompt injection threats in LLM agents: From taxonomy to analysis. arXiv. <https://arxiv.org/abs/2602.10453>

Abraham Núñez Sánchez Alumno I	Alumno 2
Dr. Héctor Xavier Limón Riaño Director de Trabajo Recepcional	Codirector de Trabajo Recepcional
Dr. Gerardo Contreras Vega Vo.Bo. Coordinador de la Academia de Experiencia Recepcional de la Licenciatura	Dr. Juan Carlos Jiménez Marquez Vo.Bo. Responsable del Grupo de Investigación Ciberseguridad y Tecnologías de la información

Consideraciones:

- 1) Casos excepcionales serán evaluados por la Academia de ER.
- 2) Tratando de un CA externo a la licenciatura en que se registra el anteproyecto, el proyecto deberá llevar el aval de los CA de la misma que se asocie con el tema.
- 3) El Vo. Bo. del Responsable de CA se obtiene en la reunión de cada CA, donde se presentan los temas del mismo para su aprobación.
- 4) El Vo. Bo. de la Coordinación de ER se obtiene en una reunión de la academia que se programa para ello.

“Lis de Veracruz: Arte, Ciencia, Luz”

www.uv.mx

